SEGURANÇA EM CLOUD:
REDES E PERÍMETRO

Material didático do aluno | Fundamentos, arquitetura, controles e situações corporativas

Objetivo: compreender como empresas protegem redes e fluxos de comunicação em nuvem, combinando segmentação, regras de tráfego, serviços gerenciados, identidade e monitoramento.

Escopo: ambientes IaaS, PaaS e SaaS, com exemplos de AWS, Azure e Google Cloud. Os cenários apresentados são fictícios e voltados ao aprendizado.

> *O perímetro em nuvem não é apenas uma barreira na borda: ele é distribuído entre recursos, redes, identidades, aplicações e dados.*

1. O que muda quando a rede vai para a nuvem?

Em um datacenter tradicional, a empresa costuma concentrar switches, roteadores e firewalls físicos. Na nuvem, ela configura redes virtuais, sub-redes, tabelas de rotas e políticas de acesso por meio de consoles, APIs e infraestrutura como código (IaC). A conectividade pode ser criada em minutos, mas um erro também pode expor serviços rapidamente.

O provedor protege a infraestrutura física e parte da camada de rede subjacente. O cliente permanece responsável por projetar a topologia, limitar acessos, configurar recursos e monitorar o tráfego, conforme o serviço contratado. Em SaaS, muitos controles de rede passam ao provedor, mas o cliente ainda gerencia identidades, configurações e integrações disponíveis.

2. Conceitos fundamentais

• **Rede virtual:** espaço lógico isolado para recursos de uma organização. Exemplos: Amazon VPC, Azure Virtual Network e Google Cloud VPC.

• **Sub-rede:** subdivisão de endereços IP, usada para separar funções, ambientes e níveis de exposição.

• **Roteamento:** regras que determinam o próximo destino dos pacotes; uma rota para a internet não significa, por si só, que todo tráfego será permitido.

• **Endereço IP público:** permite alcance pela internet quando rotas e políticas também autorizam. IP privado é usado na comunicação interna.

• **Porta e protocolo:** identificam serviços e tipos de comunicação, como TCP 443 para HTTPS e TCP 22 para SSH.

• **Perímetro:** conjunto de controles que restringe entradas, saídas e movimentações entre zonas de confiança.

3. Uma arquitetura corporativa de referência

Imagine uma loja virtual com três camadas: interface web, API de pedidos e banco de dados. O desenho seguro separa o ponto de entrada público das camadas internas. O acesso administrativo ocorre por canal controlado, e a comunicação entre componentes é explicitamente autorizada.

Zona	Recursos	Exposição esperada
Entrada pública	CDN, WAF, balanceador de carga	HTTPS para clientes
Aplicação privada	APIs, serviços de negócio	Somente origem autorizada
Dados privados	Banco de dados, armazenamento	Somente aplicação e manutenção controlada
Administração	Bastion/serviço de sessão, VPN ou ZTNA	Acesso restrito, autenticado e auditado

Fluxo desejado: usuário → HTTPS/WAF → balanceador → API privada → banco privado. O banco não precisa de IP público. Um desenvolvedor não deve conectar diretamente ao banco a partir de qualquer computador.

4. Firewalls e filtragem de tráfego

Os controles de filtragem decidem quem pode se comunicar com quem. Em ambientes de nuvem, podem existir controles no nível da instância, da sub-rede, da rede e da aplicação. É importante conhecer a direção do tráfego, o protocolo, a porta, a origem, o destino e a prioridade das regras.

Controle	Função típica	Atenção
Security Groups (AWS)	Regras de tráfego associadas a interfaces/recursos; stateful	Evitar 0.0.0.0/0 em portas administrativas
Network ACLs (AWS)	Filtragem em nível de sub-rede; stateless	Considerar regras de ida e volta
NSG (Azure)	Filtragem em sub-redes ou interfaces	Avaliar regras efetivas e prioridades
VPC firewall rules (Google Cloud)	Controle de tráfego entre recursos	Verificar escopo, prioridade e identidade dos alvos

Controle	Função típica	Atenção
WAF	Inspeção de requisições HTTP(S)	Não substitui correção de vulnerabilidades

Stateful x stateless: controles stateful acompanham o estado da conexão e, em geral, permitem automaticamente o tráfego de resposta. Controles stateless avaliam os pacotes de forma independente e podem exigir regras explícitas para retorno.

5. Segmentação e microssegmentação

Segmentar é dividir a rede em zonas com necessidades de acesso diferentes: produção, desenvolvimento, administração e dados. Microssegmentação aplica regras mais granulares entre aplicações ou cargas de trabalho, mesmo dentro de uma mesma zona. O objetivo é reduzir a superfície de ataque e dificultar movimentação lateral após uma invasão.

Exemplo: a API de pagamentos precisa consultar o banco de transações na porta específica do serviço. Ela não precisa iniciar sessões SSH em todas as máquinas do ambiente. O princípio do menor privilégio também vale para tráfego de rede.

6. Tráfego de entrada e saída

Ingress: comunicação que entra em uma rede ou recurso. **Egress:** comunicação que sai. Empresas frequentemente protegem bem a entrada e esquecem a saída. Entretanto, uma aplicação comprometida pode tentar enviar dados para um destino externo, baixar malware ou comunicar-se com servidores de comando e controle.

• Permitir somente as portas de entrada necessárias, preferencialmente HTTPS para aplicações públicas.

• Restringir acesso administrativo por identidade, dispositivo, contexto e canal seguro; evitar SSH/RDP abertos à internet.

• Definir saídas permitidas quando possível, usando proxy, firewall gerenciado, inspeção e logs.

• Usar endpoints privados para serviços gerenciados quando a arquitetura permitir, reduzindo exposição à internet.

7. Serviços de borda: WAF, DDoS, CDN e balanceamento

WAF: filtra tráfego HTTP(S) e pode bloquear padrões comuns de exploração, bots e requisições maliciosas. **Proteção DDoS:** ajuda a absorver ou mitigar grandes volumes de tráfego destinados a indisponibilizar o serviço. **CDN:** distribui conteúdo em pontos de presença e pode reduzir carga no servidor de origem. **Load balancer:** distribui requisições entre destinos saudáveis e facilita a exposição controlada de serviços.

Essas camadas se complementam. Uma aplicação com falha de autorização não fica segura apenas por estar atrás de um WAF. Um banco público também não se torna privado por haver uma CDN na frente do site.

8. Conectividade híbrida e acesso remoto

Organizações podem conectar escritórios e datacenters à nuvem por VPN site-to-site, conexões privadas dedicadas ou soluções de acesso Zero Trust. VPN cria um túnel protegido, mas não garante que todo usuário conectado deva acessar todos os recursos. Zero Trust propõe verificar explicitamente identidade, dispositivo, contexto e autorização para cada acesso relevante.

Na prática, equipes definem rotas, resolução DNS, criptografia, disponibilidade dos túneis, controles de identidade e registros de auditoria. Uma rota excessivamente ampla entre o escritório e a nuvem pode ampliar o alcance de um incidente.

9. DNS, TLS e proteção de dados em trânsito

DNS traduz nomes de domínio em endereços usados na comunicação. Registros incorretos podem direcionar usuários a destinos indevidos ou expor origens que deveriam ser privadas. TLS protege a confidencialidade e a integridade dos dados em trânsito quando corretamente configurado. Empresas devem manter certificados válidos, evitar protocolos obsoletos e proteger chaves privadas.

O uso de HTTPS no acesso público não elimina a necessidade de avaliar a criptografia nas conexões internas, especialmente quando dados sensíveis atravessam diferentes serviços ou ambientes.

10. Monitoramento, logs e resposta a incidentes

Uma rede segura precisa ser observável. Equipes de segurança coletam registros de fluxo, alterações de regras, logs de firewall, WAF, DNS e balanceadores. Correlacionam esses dados com identidades, ativos e eventos de aplicações em um SIEM ou plataforma equivalente.

• Inventariar recursos e identificar quais possuem IP público.

• Alertar quando regras administrativas forem abertas para toda a internet.

• Investigar aumentos inesperados de tráfego de saída ou conexões para destinos incomuns.

• Registrar mudanças com responsável, justificativa, aprovação e possibilidade de reversão.

• Testar periodicamente planos de resposta, restauração e continuidade.

11. Como as empresas administram esses controles

A equipe de arquitetura define zonas e fluxos necessários. A equipe de infraestrutura/cloud implementa redes, rotas e firewalls. Segurança estabelece padrões mínimos, acompanha exceções e monitora riscos. Desenvolvimento informa dependências entre serviços. Governança e compliance verificam aderência às políticas. Em organizações menores, uma pessoa pode acumular papéis, mas as responsabilidades devem continuar claras.

Um processo maduro inclui: solicitação documentada → análise de necessidade → aprovação → implementação por IaC → testes → monitoramento → revisão periódica. Mudanças emergenciais devem ter prazo, rastreabilidade e posterior revisão.

12. Situações-problema: análise corporativa

Caso 1 — Banco de dados exposto

Cenário: uma equipe ativa um IP público no banco para facilitar a manutenção. A regra de acesso aceita conexões de qualquer origem. Dias depois, o monitoramento registra tentativas automatizadas de autenticação.

Falha: exposição desnecessária do banco e ausência de restrição por origem. **Impactos:** risco de acesso indevido, vazamento e indisponibilidade. **Resposta:** restringir imediatamente a conectividade, revisar credenciais e logs, verificar indícios de comprometimento e migrar o acesso administrativo para canal privado e auditável.

> ***Discussão:*** *por que proteger a senha não é suficiente quando a superfície de ataque está exposta?*

Caso 2 — SSH aberto após manutenção

Cenário: para corrigir uma falha, um administrador libera a porta TCP 22 para 0.0.0.0/0. A alteração permanece após o atendimento.

Falha: exceção temporária sem expiração ou revisão. **Resposta:** remover a regra, avaliar logs e adotar acesso administrativo gerenciado, MFA e aprovação de mudanças. **Prevenção:** alertas automáticos e políticas que impeçam portas administrativas abertas.

Caso 3 — Invasão de aplicação e movimentação lateral

Cenário: uma API vulnerável é comprometida. Como a rede interna permite comunicação irrestrita, o invasor alcança outros serviços e tenta acessar o banco.

Falha: ausência de segmentação entre aplicações. **Resposta:** isolar a carga comprometida, preservar evidências, revogar credenciais, corrigir a falha e aplicar regras de comunicação estritamente necessárias.

Caso 4 — Exfiltração por tráfego de saída

Cenário: uma máquina virtual passa a enviar grande volume de dados para um endereço externo não relacionado ao negócio. A empresa possui regras de entrada rígidas, mas não monitora saídas.

Falha: falta de visibilidade e controle de egress. **Resposta:** investigar a origem do processo, bloquear o destino quando apropriado, preservar evidências, avaliar dados afetados e revisar regras e alertas.

Caso 5 — Site sob ataque de negação de serviço

Cenário: durante uma campanha promocional, o site recebe tráfego anormal que satura a origem e prejudica clientes legítimos.

Resposta: ativar mecanismos de proteção DDoS, distribuição de conteúdo, limitação de requisições e escalabilidade, além de monitorar o impacto. **Lição:** disponibilidade depende de

várias camadas e de um plano de continuidade.

Caso 6 — VPN corporativa com acesso amplo

Cenário: prestadores externos conectam-se à VPN e conseguem alcançar sistemas financeiros que não fazem parte de seu trabalho.

Falha: confiar na conexão à VPN como autorização geral. **Resposta:** segmentar acessos por função, reforçar MFA, revisar grupos, rotas e registros de acesso, e aplicar políticas contextuais.

13. Matriz de decisão: qual controle aplicar?

Necessidade	Controle recomendado
Publicar aplicação web	HTTPS, balanceador, WAF e proteção DDoS conforme risco
Isolar banco de dados	Sub-rede privada, regras restritivas e acesso privado
Administrar servidores	Canal gerenciado/VPN/ZTNA, MFA e auditoria
Reduzir movimentação lateral	Segmentação e regras por aplicação
Detectar exfiltração	Logs de fluxo, alertas de egress e investigação
Conectar escritório e nuvem	VPN site-to-site ou conexão privada, rotas mínimas

14. Checklist para revisão de segurança de rede

- ■ Todos os IPs públicos têm justificativa e proprietário?
- ■ As portas administrativas estão fechadas à internet?
- ■ As bases de dados estão em zonas privadas?
- ■ Há regras específicas entre aplicações, em vez de permissões amplas?
- ■ As regras de saída são conhecidas e monitoradas?
- ■ Os logs de rede e mudanças estão centralizados e retidos pelo prazo definido?
- ■ Há alertas para alterações perigosas e conexões anômalas?
- ■ As conexões híbridas seguem o menor privilégio?
- ■ As exceções possuem prazo e revisão?
- ■ A empresa testa periodicamente seus controles e procedimentos de resposta?

15. Questões de revisão

- Por que uma sub-rede privada não é, isoladamente, garantia de segurança?
- Qual a diferença entre firewall de rede e WAF?

• Como segmentação e IAM se complementam?

• Por que o monitoramento de tráfego de saída é importante?

• Qual seria a resposta inicial diante de uma regra SSH aberta para qualquer origem?

• Quais controles ajudam a reduzir o impacto de um DDoS?

• Como o modelo de responsabilidade compartilhada se aplica à configuração de firewalls na nuvem?

16. Glossário

VPC/VNet: rede virtual na nuvem. **Ingress:** tráfego de entrada. **Egress:** tráfego de saída. **WAF:** firewall de aplicações web. **DDoS:** negação de serviço distribuída. **CDN:** rede de distribuição de conteúdo. **IaC:** infraestrutura como código. **Zero Trust:** abordagem de segurança baseada em verificação explícita e privilégio mínimo. **SIEM:** plataforma de correlação e análise de eventos de segurança.

17. Referências para aprofundamento

NIST SP 800-207 — Zero Trust Architecture. https://csrc.nist.gov/pubs/sp/800/207/final

NIST SP 800-53 Rev. 5 — Security and Privacy Controls. https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final

AWS — Amazon VPC User Guide. https://docs.aws.amazon.com/vpc/

Microsoft Learn — Azure network security. https://learn.microsoft.com/azure/security/fundamentals/network-overview

Google Cloud — VPC firewall rules. https://cloud.google.com/firewall/docs/firewalls-overview

OWASP — Web Application Firewall. https://owasp.org/www-community/Web_Application_Firewall